

❖ السؤال ١ – تحديد المشكلة

- ما هي الثغرة الأمنية الموجودة في هذا السيناريو؟
- الثغرة هي URL Parameter Tampering ، يمكن للمستخدم العادي تغيير قيمة المتغير type في الرابط أعلاه وبدون أي صلاحية مخولة له .
- اشرح بإيجاز لماذا يُعد هذا السلوك خطرًا أمنيًا؟
- لأن هذه البيانات والمعلومات التي تظهر خاصة للـ admin لا يجوز لأي مستخدم أن يراها وهذا انتهاك للخصوصية .

❖ السؤال ٢ – شرح الهجوم

- اشرح كيف يمكن للمهاجم استغلال هذه الثغرة؟
- يستغل هذه الثغرة بالوصول الى البيانات بدون التحقق من صلاحية الوصول
- ما الذي يتم تعديله بالضبط في عنوان URL ، ولماذا يسمح التطبيق بهذا الوصول؟
- عن طريق تغيير قيمة البراميتر في الرابط type--- من user-----الى admin